RUNBOOK

1,122 repos just leaked secrets from one checkbox

Not a hack. Not a bug. A default permission setting.

- Researchers scanned 104,185 public Claude Code settings files
- 1,122 of them had real passwords and API keys inside
- Widen the search and the number jumps past 2,500 secrets

WHAT HAPPENED

The feature is called don't ask again

It's built to save developers time on repeated approvals

- Claude Code lets you approve a shell command permanently
- Click once, and it saves the full command to a local file
- That file often includes the credentials you just typed
- If that file gets committed, the secrets go public with it

WHY IT SPREAD

One convenience click, repeated at scale

This is the part worth understanding

- No single person did anything reckless or unusual
- Every developer just used the tool the way it's designed
- The default behavior quietly multiplied the same mistake
- Scale turned a small risk into a dataset of thousands

THE REAL LESSON

This is a workflow failure, not a model failure

The AI did exactly what it was told to do

- The model isn't leaking secrets on its own initiative
- The permission system is what decides what gets saved
- Nobody designed for what happens after approval is granted
- Convenience settings need the same scrutiny as config files

VENDOR RESPONSE

Anthropic has acknowledged the gap

But there's no formal fix or advisory yet

- Claude Code's team lead responded in a public forum
- Secret scrubbing was never part of the original design
- Proposed fixes are still being discussed, not shipped
- Worth watching this space before assuming it's resolved

TEACHING POINT

Check this file before you commit anything

A two-minute habit that closes most of the risk

- .claude/settings.local.json is the file to check first
- Add it to .gitignore if it isn't already excluded
- Run a secret scanner before pushing to a public repo
- Treat every agent's local config like a credentials file

TAKEAWAY

Audit your agent permissions, not just your code

The next incident like this won't be the last one

- Review what your coding agent saves and where
- Don't assume defaults were chosen with security in mind
- Treat 'don't ask again' settings as a design decision to own

CTA

What's your team's policy on agent permissions?

Most teams don't have one written down yet

- If this made you check a repo, that's the right instinct
- Happy to compare notes on how others are handling this